

Lab: Username enumeration via different responses

APPRENTICE



LAB



Solved

This lab is vulnerable to username enumeration and password brute-force. It uses a predictable username and password, which can be found in the following

- Candidate usernames
- Candidate passwords

To solve the lab, enumerate a valid username, brute-force this user's password.

Lab: 2FA simple bypass



APPRENTICE

LAB

✓ Solved

This lab's two-factor authentication can be bypassed. You have already obtained a valid username and password, but you do not have access to the user's 2FA verification code. To solve the lab, access Carlos's account page.

- Your credentials: `wiener:peter`
- Victim's credentials: `carlos:montoya`

Lab: Password reset broken logic



APPRENTICE

⚙️ LAB

✓ Solved

This lab's password reset functionality is vulnerable. To solve the lab, reset Carlos's password then log in and access the "My account" page.

- Your credentials: `wiener:peter`
- Victim's username: `carlos`

Lab: Unprotected admin functionality

APPRENTICE



LAB



Solved

This lab has an unprotected admin panel.

Solve the lab by deleting the user `carlos`.

Lab: Unprotected admin functionality with unpredictable URL



APPRENTICE



LAB



Solved

This lab has an unprotected admin panel. It's located at an unpredictable location, but the location is disclosed somewhere in the application.

Solve the lab by accessing the admin panel, and using it to delete the user `carlos`.

Lab: User role controlled by request parameter

APPRENTICE

LAB

✓ Solved

This lab has an admin panel at `/admin`, which identifies administrators using a forgeable cookie.

Solve the lab by accessing the admin panel and using it to delete the user `carlos`.

You can log in to your own account using the following credentials: `wiener:peter`

Lab: User role can be modified in user profile



APPRENTICE

LAB

✓ Solved

This lab has an admin panel at `/admin` . It's only accessible to logged-in users with a `roleid` of 2.

Solve the lab by accessing the admin panel and using it to delete the user `carlos` .

You can log in to your own account using the following credentials: `wiener:pete` r

Lab: User ID controlled by request parameter

APPRENTICE



LAB



Solved

This lab has a horizontal privilege escalation vulnerability on the user account page. To solve the lab, obtain the API key for the user `carlos` and submit it as the solution. You can log in to your own account using the following credentials: `wiener:peter`

Lab: User ID controlled by request parameter, with unpredictable user IDs



APPRENTICE

LAB

✓ Solved

This lab has a horizontal privilege escalation vulnerability on the user account page, but identifies users with GUIDs.

To solve the lab, find the GUID for `carlos`, then submit his API key as the solution.

You can log in to your own account using the following credentials: `wiener:peter`

Lab: User ID controlled by request parameter with data leakage in redirect



APPRENTICE

 LAB

 Solved

This lab contains an **access control** vulnerability where sensitive information is leaked in the body of a redirect response.

To solve the lab, obtain the API key for the user `carlos` and submit it as the solution.

You can log in to your own account using the following credentials: `wiener:pete`

APPRENTICE

LAB

✓ Solved

Lab: User ID controlled by request parameter with password

This lab has user account page that contains the current user's existing password, prefilled in the password field. To solve the lab, retrieve the administrator's password, then use it to delete carlos. You can log in to your own account using the following credentials: wiener:peter

Lab: Insecure direct object references

APPRENTICE

⚗ LAB

✓ Solved

This lab stores user chat logs directly on the server's file system, and retrieves them using st. Solve the lab by finding the password for the user `carlos`, and logging into their account.

Broken Access Control

● Five-Star Feedback



Get rid of all 5-star customer feedback.



Q 0/4

Broken Authentication

● Password Strength



Log in with the administrator's user credentials
without previously changing them or applying SQL



Brute Force

Tutorial

With Coding Challenge



0/4

Broken Access Control

● View Basket



View another user's shopping basket.

Tutorial

Good for Demos



0/4

Broken Access Control

● Admin Section



Access the administration section of the store.

Good for Demos

With Coding Challenge



0/4